Dr. Ekta API - Frontend vs Admin Endpoints

API Endpoints — Frontend vs Admin Panel
How to tell them apart
Table 1 — Frontend endpoints (website, no token)
Table 2 — Admin panel endpoints (token required)
Table 3 — Same resource, both sides (the differentiation cheat-sheet)
Exceptions and footnotes (read before wiring the frontend)

API Endpoints — Frontend vs Admin Panel

Base URL local: `http://localhost:4000`. Every response is JSON except CSV (`leads/export`), XML (`sitemap.xml`), plain text (`robots.txt`), and the redirect resolver (HTTP 301/302).

How to tell them apart

	Frontend endpoints	Admin panel endpoints
Prefix	`/api/public/...`	`/api/admin/...`
Auth	None (open to the internet)	`Authorization: Bearer <accessToken>` on every call **except** login/refresh/logout
Writes	Only 2: submit enquiry, log Practo click	Full create/update/delete on everything
Sees drafts?	**Never** — only `status: published` items (videos: `published`, not `hidden`)	Yes — sees all statuses, filters by `status`
Internal fields	Excluded (`createdBy`, notes, full user objects)	Included (populated `createdBy`, full docs)
Caching	`Cache-Control` per content type (profile 1h, lists 5min, home 1min)	`no-store` everywhere

	Frontend endpoints	Admin panel endpoints
Rate limits	Reads 100/min, enquiry 20/min (per IP)	Login/refresh 10 per 15 min

Only `published` content is ever public. Publishing = setting `status: "published"` on create/update. There is no review workflow: no submit/approve/reject endpoints exist.

Table 1 — Frontend endpoints (website, no token)

Method	Endpoint	Purpose	Notes
GET	`/`	API info (`name`, `version`, `status`)	Health-check hel
GET	`/api/public/health`	Liveness probe	`{ status: "ok"` `timestamp }`
GET	`/api/public/clinic-info`	Phones, address, timings, map, socials, email	Cached 1h + ETa powers header/footer/co
GET	`/api/public/treatments?page=&limit=&search=`	Published treatment cards	Limit capped at full-text search
GET	`/api/public/treatments/:slug`	Treatment detail (sections, FAQs, SEO)	404 unless publi
GET	`/api/public/articles?page=&limit=&category=&tags=&search=`	Published article list (**no `body`**)	Teaser list; link t detail for full tex
GET	`/api/public/articles/:slug`	Article detail (full body, sources, byline)	404 unless publi
GET	`/api/public/profile/`	Doctor bio, qualifications, photo/video	Cached 1h
GET	`/api/public/testimonials/?treatmentTag=`	Published patient stories	Filter by treatme for treatment pag
GET	`/api/public/gallery/?treatmentTag=`	Published before/after items	`beforeImg.url` / `afterImg.url` fo sliders
GET	`/api/public/videos/?category=`	Published videos + transcripts	Embed `url`, shov `transcript` for accessibility
GET	`/api/public/instagram-posts/`	Curated grid	Everything store public; links out

Method	Endpoint	Purpose	Notes
			`permalink`
GET	`/api/public/announcements/`	Published notices (ordered)	`order` then newe drafts hidden
GET	`/api/public/home/`	Homepage aggregate (treatments ≤6, articles ≤4, videos ≤4, testimonials ≤3)	One call powers whole homepage
POST	`/api/public/enquiry`	Enquiry form → creates a Lead	`201 { message, leadId }`; honey filled returns fak `200` with no lead `422` on bad phone/unknown treatment/medic fields; needs `captchaToken` w captcha is configured
GET	`/api/public/booking-cta`	Practo `{ provider, profileUrl, bookingUrl }`	`404` when no acti provider — hide/fallback the Book button
POST	`/api/public/leads/practo-click`	Fire-and-forget click log	Always `200`; sen without awaiting
GET	`/api/public/sitemap.xml`	Generated sitemap (published content)	XML; videos lin by id
GET	`/api/public/robots.txt`	Generated robots (points at sitemap)	Plain text
GET	`/api/public/redirect/:path`	Legacy-URL redirect	`301`/`302` to `toPat` else `404`

Table 2 — Admin panel endpoints (token required)

Auth: `POST /api/admin/auth/login` → store pair → send `Authorization: Bearer <accessToken>` → silent `POST /api/admin/auth/refresh` on 401 → `POST /api/admin/auth/logout` on exit.

Method	Endpoint	Purpose	
POST	`/api/admin/auth/login`	Login *(no token)*	`{ emai` user, `refres` `401 In` 5 fails
POST	`/api/admin/auth/refresh`	Rotate token pair *(no token)*	Body c old refi
POST	`/api/admin/auth/logout`	Revoke refresh token *(no token)*	Always
GET	`/api/admin/auth/me`	Current admin	`{ user` `email,`
GET / PUT	`/api/admin/clinic-info`	Read / update practice info	PUT al practic phones mapCo socialL legalEr locatio
POST	`/api/admin/media/upload`	Step 1: validate + Cloudinary signature bundle	`{ file` `size }` type/siz 400/80
POST	`/api/admin/media/confirm`	Step 2: create MediaAsset	Send **b** `public` http(s) `optimi` stored
GET	`/api/admin/media?page=&limit=&mimeType=`	List uploads (own only)	`upload`
GET / DELETE	`/api/admin/media/:id`	One asset / delete it	Delete `usedIn`
GET	`/api/admin/treatments?status=&search=`	List all statuses	Limit c
GET / POST / PUT / DELETE	`/api/admin/treatments[/:id]`	Full treatment CRUD	`status` set dire sanitize id
GET	`/api/admin/articles?status=&category=&search=`	List all statuses	Limit c
GET / POST / PUT / DELETE	`/api/admin/articles[/:id]`	Full article CRUD	Same c review editabl
GET	`/api/admin/testimonials?status=&treatmentTag=`	List all statuses	Status routers

Method	Endpoint	Purpose	
GET / POST / PUT / DELETE	`/api/admin/testimonials[/:id]`	Full testimonial CRUD	No con updates
GET	`/api/admin/gallery?status=&treatmentTag=`	List all statuses	Status :
GET / POST / PUT / DELETE	`/api/admin/gallery[/:id]`	Full gallery CRUD	`before` require
GET	`/api/admin/videos?status=&category=`	List all statuses	—
GET / POST / PUT / DELETE	`/api/admin/videos[/:id]`	Full video CRUD	`status` `publis` the **full** (valida
GET	`/api/admin/instagram-posts/`	List curated posts	Status : status f
GET / POST / PUT / DELETE	`/api/admin/instagram-posts[/:id]`	Full curated-post CRUD	`image` - require optiona
GET	`/api/admin/announcements?status=`	List all statuses	Status :
GET / POST / PUT / DELETE	`/api/admin/announcements[/:id]`	Full announcement CRUD	`title` - create; `draft\` body sa
GET	`/api/admin/profile/`	Doctor profile (admin view)	Same r
PUT	`/api/admin/profile/`	Update profile	Bio sar settable
GET / PUT	`/api/admin/home/config`	Read / replace featured-id arrays	`{ feat` `featur` `featur` `featur`
GET	`/api/admin/leads?status=&source=&startDate=&endDate=&search=`	Lead table	Limit c = `lead`
GET	`/api/admin/leads/stats`	Funnel cards	`{ bySt` `total,`
GET	`/api/admin/leads/export?...`	CSV download (streamed, formula-escaped)	Same f
GET / PUT /	`/api/admin/leads/:id`	One lead / update	Update `leadSt`

Method	Endpoint	Purpose	
DELETE		status+notes / delete	`appoin` `notes,` `treatm` unknov
GET / PUT	`/api/admin/booking-provider`	Read / upsert Practo URLs	`404` on unconf button
GET	`/api/admin/practo-clicks`	Click totals + 30-day daily stats	Option
GET	`/api/admin/redirects?search=`	List redirects	Limit c
GET / POST / PUT / DELETE	`/api/admin/redirects[/:id]`	Full redirect CRUD	`fromPa` prepen PUT; `4` `DUPLIC`
GET	`/api/admin/analytics/reports/monthly`	Monthly aggregates	Live: e events;
GET	`/api/admin/analytics/events?...`	Raw event list	Limit c

Table 3 — Same resource, both sides (the differentiation cheat-sheet)

Resource	Frontend (public, published-only)	Admin panel (all statuses, full CRUD)
Treatments	`GET /api/public/treatments`, `GET .../treatments/:slug`	`GET/POST/PUT/DELETE /api/admin/treatments[/:id]`
Articles	`GET /api/public/articles`, `GET .../articles/:slug`	`GET/POST/PUT/DELETE /api/admin/articles[/:id]`
Testimonials	`GET /api/public/testimonials/`	`GET/POST/PUT/DELETE /api/admin/testimonials[/:id]`
Gallery	`GET /api/public/gallery/`	`GET/POST/PUT/DELETE /api/admin/gallery[/:id]`
Videos	`GET /api/public/videos/`	`GET/POST/PUT/DELETE /api/admin/videos[/:id]`

Resource	Frontend (public, published-only)	Admin panel (all statuses, full CRUD)
Instagram	`GET /api/public/instagram-posts/`	`GET/POST/PUT/DELETE /api/admin/instagram-posts[/:id]`
Announcements	`GET /api/public/announcements/`	`GET/POST/PUT/DELETE /api/admin/announcements[/:id]`
Profile	`GET /api/public/profile/`	`GET /api/admin/profile/`, `PUT ...`
Homepage	`GET /api/public/home/`	`GET/PUT /api/admin/home/config`
Booking	`GET /api/public/booking-cta`	`GET/PUT /api/admin/booking-provider`

Exceptions and footnotes (read before wiring the frontend)

1. **Three admin-prefix routes need no token:** `POST .../auth/login`, `POST .../auth/refresh`, `POST .../auth/logout`. Everything else under `/api/admin` 401s without a token.
2. **Two public handlers also answer under `/api/admin`:** `GET /api/admin/booking-cta` and `POST /api/admin/leads/practo-click` (same handlers, no token needed). Prefer the `/api/public` URLs.
3. **`GET /api/admin/home/` serves the public aggregate** (same as `/api/public/home/`). Admin config lives at `/api/admin/home/config`.
4. **`GET /api/public/home/config` requires a token** despite the public prefix — treat it as admin-only.
5. **No workflow endpoints exist** (`submit`/`approve`/`reject`/`publish` all return `404 Route not found`). Publish by sending `status: "published"`.
6. **No consent fields exist** on testimonials/gallery — do not send `consent`; it is ignored.
7. **Error shape is uniform:** `{ error, code }`, plus `details[]` on `422`. In tests, `stack` is attached — never in production.